

Hands-On-Learning: Responding to a Cloud Security Incident with Detection and Forensics

Scenario

You are part of the Cloud SOC (Security Operations Center). During routine monitoring, GuardDuty raises a **high-severity finding**: suspicious API calls from an IAM user key that was accidentally pushed to GitHub. Your team must contain the threat, preserve evidence, and prepare for a post-mortem.

By completing this lab, you will create an **Incident Response (IR) playbook**, execute a **forensic preservation workflow**, and generate artifacts for peer review.

Instructions for Learners

1 Preparation

Ensure access to an AWS sandbox account (or simulate using architecture diagrams if no live environment is available).

Review the following tools/services:

GuardDuty → for detection

CloudTrail → for event history

IAM → for key deactivation & rotation

EC2 Snapshots → for forensic evidence

2 Containment Actions

Identify the compromised IAM key from the GuardDuty finding.

In IAM, immediately deactivate the key.

Document why deactivation (not deletion) is the safest first step.

If the IAM user is not critical, quarantine it by detaching policies.

Artifact: A short **checklist** of containment actions.

3 Forensic Preservation

Simulate (or diagram) how you would:

- Snapshot **EC2 volumes** from any suspicious instance.

- Mark the snapshot **read-only**.

- Clone the snapshot into a quarantined VPC for investigation.

Run **CloudTrail Event History** to filter for:

- Delete*, Disable*, Stop* API calls

- Region = all regions

Save search queries or diagram the process.

Artifact: A forensic evidence workflow diagram or query list.

4 Post-Mortem Draft

Document the following in a one-page template:

Timeline: when the key leaked, when GuardDuty flagged it, when containment happened.

Root Cause: control gap (e.g., no secret scanning on GitHub).

Lessons Learned: controls to add (e.g., enable Amazon Macie or GitHub secret scanning).

Follow-Up Actions: policy to enforce key rotation & prevent inline credentials.

Artifact: A draft **post-mortem report** (short, bulleted format).

5 Peer Review

Exchange artifacts (checklist + workflow + post-mortem) with a peer.

Review for:

Completeness of containment steps.

Accuracy of forensic preservation.

Depth of root cause analysis.

Provide written or verbal feedback.

Reflection

Which part of the IR process felt the most urgent?

How would you ensure your team doesn't miss key API calls during investigation?

What ongoing detection + prevention controls (e.g., Config rules, Macie, GuardDuty auto-remediation) would you add to avoid future incidents?

Final Outcome

By completing this lab, you have:

Built a **containment checklist** for IAM key compromise.

Created a **forensic workflow artifact** (snapshotting, CloudTrail queries).

Drafted a **post-mortem template** identifying root cause and lessons learned.

Participated in **peer review** to refine your incident response skills.

Instructions for Documenting and Sharing The Project for Peer Review

Document the Project



Use word processing software to create your report.

Ensure all sections of the project document structure are completed.

Proofread and edit your report for clarity and accuracy.

Reflection

Which responsibilities surprised you most (things you thought the provider handled but are actually customer tasks)?

How would this matrix change for a multi-cloud environment?

How could this matrix reduce risk in real-world onboarding and training?

Final Outcome

Created a **Shared Responsibility Matrix** for IaaS, PaaS, and SaaS.

Produced a peer-reviewed artifact suitable for training and executive communication.

Built a reusable tool to guide future cloud migrations and compliance efforts.

Next Steps

Expand the matrix to include **specific services** (EC2, RDS, S3, Google Workspace, etc.).

Layer in **framework mapping** (e.g., CIS, ISO, NIST) to show compliance overlap.

Use this matrix as a foundation for a **Cloud Security Onboarding Guide** in your organization.



Share the Project

Document: Save the report in PDF format.

Upload: Share in the “Peer Review” area of the course shell with a brief description.



Peer Review

Review the projects submitted by your peers.

Provide constructive feedback and comments on their work.